🔍 CEH v13 — Module 04: Enumeration

> **Personal lab notes & command reference** | Certified Ethical Hacker (C|EH) v13
> Documented for learning and revision purposes. No exam answers or proprietary content reproduced.

📌 What is Enumeration?

Enumeration is the process of **actively querying a target system** to extract detailed information such as:

- Usernames, groups, and machine names
- Network shares and services
- Open ports and running protocols
- OS versions and BIOS info

> Unlike scanning (passive-ish), enumeration creates **active connections** to target systems. It follows reconnaissance and scanning in the ethical hacking kill chain.

🗂️ Labs Index

#	Lab	Protocol/Tool	Port
1	NetBIOS Enumeration	`nbtstat`, `net use`	137-139
2	SNMP Enumeration	`snmpwalk`	161 (UDP)
3	LDAP Enumeration	AD Explorer	389
4	NFS Enumeration	RPCScan, SuperEnum	2049
5	DNS Enumeration	`dig`, `nslookup`	53
6	SMTP Enumeration	`nmap` scripts	25
7	Enumeration Tools	Global Network Inventory	—

Lab 1: NetBIOS Enumeration

🧠 Concept

NetBIOS (Network Basic Input Output System) allows applications on different computers to communicate within a LAN. Windows uses it for **file and printer sharing**. A NetBIOS name is a 16-character identifier — 15 for the device name, 1 reserved for service type.

> ⚠️ Even when not actively in use, NetBIOS runs on Windows — making it a soft target for enumeration.

Attack surface: Reading/writing remote shares, extracting name tables, or launching DoS attacks.

🖥️ Environment

Role	Machine	IP
Attacker	Windows Server 2019	—
Target	Windows 11	10.10.1.11

⚙️ Commands & Explanations

```cmd
nbtstat -a 10.10.1.11
```

> **One-liner:** Query a remote machine's NetBIOS name table over the network using its IP address — reveals device name, logged-in users, and services registered via NetBIOS.

Flag	Meaning
`-a`	Display NetBIOS name table of a **remote** machine by IP
`-A`	Same as `-a` but resolves via hostname instead of IP
`-c`	Show the local NetBIOS **name cache** (recently resolved names + IPs)
`-n`	Display the **local** machine's NetBIOS name table

```cmd
```

```
nbtstat -c
```

> **One-liner:** List the local NetBIOS name cache — shows recently contacted machines, their names, and resolved IP addresses. No authentication needed.

```cmd
net use
```

> **One-liner:** Display all current network connections, shared drives, and their connection status — helps map accessible resources on the network from the current session.

🔑 Key Takeaways

- NetBIOS name tables can be read **without authentication** (null session not required for `nbtstat`)
- The 16th character in a NetBIOS name indicates the **service type** (e.g., `<00>` = Workstation, `<20>` = File Server)
- `net use` shows shared resources — if writable shares exist, this can lead to data exfiltration or DoS

Lab 2: SNMP Enumeration

🧠 Concept

SNMP (Simple Network Management Protocol) is an application-layer protocol running on **UDP port 161** used to manage network devices (routers, switches, hubs). It uses two components:

- **SNMP Agent** — runs on the managed device
- **SNMP Management Station** — queries the agent

SNMP uses **community strings** as passwords. The default string `public` (read-only) is commonly left unchanged, making devices trivially enumerable.

> Community strings in SNMPv1/v2c are sent in **plaintext** — easily intercepted on the wire.

OID (Object Identifier): A unique address in the MIB tree that identifies a specific piece of information (e.g., system uptime, interface stats).

🖥️ Environment

Role	Machine	IP
Attacker	Parrot Security (Linux)	—
Target	Windows Server 2022	10.10.1.22

⚙️ Commands & Explanations

```bash
snmpwalk -v1 -c public 10.10.1.22
```

> **One-liner:** Walk the entire SNMP MIB tree on the target using SNMPv1 and the default "public" community string — dumps all OIDs, variables, and system configuration data.

Flag	Meaning
`-v1`	Use SNMP **version 1**
`-v2c`	Use SNMP **version 2c** (more data, still no encryption)
`-c public`	Set the **community string** to "public" (default read-only string)

```bash
snmpwalk -v2c -c public 10.10.1.22
```

> **One-liner:** Same walk using SNMPv2c — often returns more structured data including server info, user credentials in some configs, and running service parameters.

🔑 Key Takeaways

- SNMPv1 and v2c are **insecure by design** — community strings travel in cleartext
- Default community strings (`public`, `private`) are almost universally tested first in pentests
- SNMPv3 introduced encryption and authentication — but many devices still run v1/v2c

- Data returned can include: ARP tables, routing tables, running processes, OS info, and sometimes **credentials**

Lab 3: LDAP Enumeration

🧠 Concept

LDAP (Lightweight Directory Access Protocol) is used to access and maintain distributed directory information (like Active Directory) over **TCP port 389**. It's essentially the phone book of a corporate network.

Information stored in LDAP includes: usernames, email addresses, department info, server names, group memberships.

> Anonymous LDAP queries are possible on misconfigured servers — exposing the entire directory structure without credentials.

DSA (Directory System Agent): The server component that responds to LDAP requests.
BER (Basic Encoding Rules): The encoding format used to transmit LDAP data.

🖥️ Environment

Role	Machine	IP
Attacker	Windows Server 2019	—
Target (AD)	Windows Server 2022	10.10.1.22

⚙️ Tool: Active Directory Explorer (AD Explorer)

AD Explorer is a Sysinternals tool that acts as a **graphical LDAP browser** for Active Directory. It allows navigation of the AD tree, viewing object properties, and modifying attributes.

Connection: `Connect to: 10.10.1.22` → enters the AD domain directly.

AD Tree path explored:

```
DC=CEH, DC=com
  └── CN=Users
        └── [individual user objects]
              └── attributes: displayName, userPrincipalName, mail, etc.
```

🔑 Key Takeaways

- LDAP enumeration reveals **organizational structure** — department names, manager-subordinate relationships, email formats
- Knowing email formats (e.g., `firstname.lastname@company.com`) enables **spear phishing** and **password spraying**
- `userPrincipalName` is used for login in Windows environments — valuable for brute force targeting
- Modifying attributes (as shown in lab) = **proof of insufficient access controls** on the AD

Lab 4: NFS Enumeration

🧠 Concept

NFS (Network File System) allows users to access remote files as if they were local. It runs on **TCP/UDP port 2049** and is managed by RPC (Remote Procedure Call).

NFS enumeration identifies:

- Exported/shared directories on the server
- Client IPs connected to the NFS server
- Accessible paths (sometimes without authentication)

> If NFS exports are world-readable or misconfigured, an attacker can **spoof a trusted IP** and gain full read/write access to remote shares.

🖥️ Environment

Role	Machine	IP
Attacker	Parrot Security (Linux)	—
Target (NFS Server)	Windows Server 2019	10.10.1.19

⚙️ Commands & Explanations

```bash
nmap -p 2049 10.10.1.19
```

> **One-liner:** Check if the NFS port (2049) is open on the target — confirms whether the NFS service is active and reachable before running dedicated enumeration tools.

```bash
cd SuperEnum
echo "10.10.1.19" >> Target.txt
./superenum
# Input: Target.txt
```

> **One-liner:** Run SuperEnum against IPs listed in a text file — performs broad enumeration of all open ports including NFS (2049), listing services, banners, and configurations.

> ⚠️ If script fails: `chmod +x superenum` to make it executable first.

```bash
python3 rpc-scan.py 10.10.1.19 --rpc
```

> **One-liner:** Use RPCScan to communicate directly with RPC services on the target — lists all registered RPC services, NFS mountpoints, and accessible directories, highlighting misconfigurations.

Flag	Meaning
`--rpc`	Query the **portmapper** (RPC service registry) for all registered services

---

🔑 Key Takeaways

- NFS port is **2049** — always check this during enumeration of Linux/mixed environments
- `showmount -e <IP>` (not in this lab but standard) lists exported NFS shares
- Misconfigured NFS with `no_root_squash` = attacker can write as root to the share
- RPCScan checks for misconfigurations that lead to unauthorized mount access

---

Lab 5: DNS Enumeration

🧠 Concept

DNS (Domain Name System) translates domain names to IP addresses. DNS enumeration

extracts:

- Name server (NS) records
- Mail exchanger (MX) records
- Zone files (if zone transfer is allowed)
- SOA (Start of Authority) records — admin email, primary NS, serial number

Zone Transfer (AXFR): A mechanism for replicating DNS records from primary to secondary servers. If misconfigured to allow transfers from **any** IP, an attacker gets the entire DNS map of the domain.

> A successful zone transfer = full internal DNS layout including internal hostnames, IPs, and subdomains.

🖥️ Environment

Role	Machine
Linux Attacker	Parrot Security
Windows Attacker	Windows 11
Target Domain	certifiedhacker.com

⚙️ Commands & Explanations

```bash
dig ns www.certifiedhacker.com
```

> **One-liner:** Query the DNS infrastructure for the name servers of a domain — reveals which DNS servers are authoritative, giving you targets for zone transfer attempts.

Part	Meaning
`dig`	DNS lookup utility (Linux)
`ns`	Request **Name Server** records
Result in `ANSWER SECTION`	Lists NS hostnames (e.g., `ns1.bluehost.com`)

```bash
dig @ns1.bluehost.com www.certifiedhacker.com axfr
```

> **One-liner:** Attempt a full DNS zone transfer from the specified name server — if allowed, returns every DNS record in the zone; if denied, returns "Transfer failed."

Part	Meaning
`@ns1.bluehost.com`	Direct the query to this specific nameserver
`axfr`	Request **full zone transfer** (all records)

```cmd
nslookup
> set querytype=soa
> certifiedhacker.com
```

> **One-liner:** Switch nslookup to SOA mode and query a domain to retrieve administrative DNS info — reveals the primary name server, responsible admin email address, and zone serial number.

Part	Meaning
`set querytype=soa`	Request **Start of Authority** record
SOA record contains	Primary NS, admin email, refresh/retry/expire timers

---

```cmd
ls -d ns1.bluehost.com
```

> **One-liner (nslookup interactive mode):** Request a zone transfer from the name server — equivalent to `axfr` in dig; returns all DNS records if transfer is permitted, or a refusal message.

🔑 Key Takeaways

- Zone transfer (`axfr`) should be **restricted to trusted secondary DNS servers only** — open

transfers are a critical misconfiguration

- SOA records reveal the **admin's email address** (formatted as `admin.domain.com` in DNS notation, meaning `admin@domain.com`)
- Even if zone transfer fails, the NS records themselves are useful for further enumeration
- Always test zone transfer on **all name servers** of a target — some may be misconfigured even if the primary isn't

---

Lab 6: SMTP Enumeration

🧠 Concept

SMTP (Simple Mail Transfer Protocol) handles outbound email delivery. It runs on **TCP port 25** (also 587, 2525). SMTP enumeration helps identify:

- Valid user accounts on a mail server
- Whether the server acts as an **open relay** (sends mail for anyone — exploitable for spam)
- Supported SMTP commands (can reveal server software version)

SMTP has commands like `VRFY` (verify user) and `EXPN` (expand mailing list) that, if enabled, directly expose valid usernames.

🖥️ Environment

Role	Machine	IP
Attacker	Parrot Security (Linux)	—
Target	Windows Server 2019	10.10.1.19

⚙️ Commands & Explanations

```bash
nmap -p 25 --script=smtp-enum-users 10.10.1.19
```

> **One-liner:** Run Nmap's SMTP user enumeration script against port 25 — uses VRFY, EXPN, and RCPT TO commands to identify valid email user accounts on the target mail server.

Part	Meaning
`-p 25`	Target **port 25** (SMTP)
`--script=smtp-enum-users`	NSE script that probes for valid usernames

```bash
nmap -p 25 --script=smtp-open-relay 10.10.1.19
```

> **One-liner:** Test if the target SMTP server is an open relay — an open relay accepts and forwards email for any sender/recipient, enabling it to be abused for spam campaigns.

Part	Meaning
`--script=smtp-open-relay`	Tests 16 different relay bypass combinations

```bash
nmap -p 25 --script=smtp-commands 10.10.1.19
```

> **One-liner:** Retrieve the list of SMTP commands supported by the target mail server — helps fingerprint the mail software and identify if dangerous commands like VRFY or EXPN are enabled.

Part	Meaning
`--script=smtp-commands`	Sends `EHLO` and parses the server's capability response

🔑 Key Takeaways

- **VRFY** command confirms if a username exists — should be disabled on production servers
- **EXPN** expands mailing lists to reveal member addresses — another disclosure risk
- An **open relay** = free spam infrastructure for attackers; also gets the server **IP-blacklisted**
- Enumerated usernames → feed directly into **password spraying** attacks
- Nmap's `--script` argument is backed by the **Nmap Scripting Engine (NSE)** — hundreds of scripts available at `/usr/share/nmap/scripts/`

Lab 7: Global Network Inventory

🧠 Concept

Global Network Inventory is an **agent-free audit scanner** — it connects to remote machines using Windows credentials and enumerates everything without installing software on the target. It works across IP ranges or individual hosts.

It's particularly useful for:

- Asset inventory in corporate environments
- Identifying outdated software and OS versions
- Mapping shared folders and active services
- Extracting BIOS, hardware, and hotfix information

🖥️ Environment

Role	Machine	IP
Attacker/Scanner	Windows 11	—
Target	Windows Server 2022	10.10.1.22

📊 Data Categories Enumerated

Tab	What It Reveals
Scan Summary	General overview: hostname, domain, OS
Operating System	Full OS name, version, build number, install date
BIOS	Manufacturer, BIOS version, release date
NetBIOS	Registered NetBIOS names and service types
User Groups	Local groups and their members
Users	User accounts, last login, account status
Services	Running services, start type, service account

Tab	What It Reveals
Installed Software	All installed applications and versions
Shares	Shared folders, paths, and permissions
Processors / Memory	Hardware specs
Hot Fixes	Installed Windows patches (missing ones = vulnerabilities)

🔑 Key Takeaways

- Agent-free scanning = **no traces left on the target** (assuming credentials are valid)
- Missing hotfixes from the **Hot Fixes** tab → directly actionable vulnerability leads
- Installed software list helps identify **outdated/vulnerable applications** (e.g., old Adobe, Java)
- Shares tab reveals paths that may be **writable or publicly accessible**
- In real pentests, credentials are obtained first (via phishing, OSINT, etc.) before running this kind of deep scan

---

🛠️ Tools Quick Reference

Tool	Type	Protocol	Key Use
`nbtstat`	Windows built-in	NetBIOS/TCP	Remote name table, cache
`net use`	Windows built-in	SMB	View/map network shares
`snmpwalk`	Linux CLI	SNMP UDP/161	Walk MIB tree, dump OIDs
AD Explorer	GUI (Sysinternals)	LDAP TCP/389	Browse & modify Active Directory
RPCScan	Python script	RPC/NFS	List RPC services, NFS shares
SuperEnum	Bash script	Multi	Broad open port enumeration
`dig`	Linux CLI	DNS UDP/53	NS lookup, zone transfer attempt
`nslookup`	Cross-platform	DNS UDP/53	SOA query, zone transfer (Windows)

Tool	Type	Protocol	Key Use
`nmap` + NSE	Linux CLI	Multi	SMTP user enum, relay test, commands
Global Network Inventory	GUI	SMB/WMI	Full Windows host audit

🔐 Defensive Takeaways (Blue Team Perspective)

Vulnerability	Fix
NetBIOS exposed	Disable NetBIOS over TCP/IP if not needed
Default SNMP community strings	Change from `public`/`private`; upgrade to SNMPv3
Anonymous LDAP queries allowed	Require authentication for all LDAP binds
NFS exports misconfigured	Use `root_squash`, restrict exports by IP
DNS zone transfer open	Restrict AXFR to trusted secondary NS IPs only
SMTP VRFY/EXPN enabled	Disable in mail server config
Open SMTP relay	Authenticate outbound mail (SPF, DKIM, DMARC)

📎 Notes

- **Lab environment:** CEH v13 iLabs (EC-Council official)
- **Target IPs used in labs:** 10.10.1.11, 10.10.1.19, 10.10.1.22 (internal lab network only)
- **Attacker machines:** Parrot Security OS (Linux), Windows Server 2019, Windows 11
- All techniques documented here are performed in a **controlled lab environment**

Module 04 complete. Module 05 (Vulnerability Analysis) notes coming soon.